INFORME DE AUDITORIA DE PRIVACIDAD

Sistema de Gestion de Privacidad de la Informacion (PIMS)
Universidad Nacional de San Agustin de Arequipa

Fecha de emision:	22 de October de 2026, 14:19 hrs
Elaborado por:	PrivAudit AI — Agente de Evaluacion de Riesgos de Privacidad
Marco normativo:	ISO 27701:2025 | ISO 27001:2022 | ISO 42001:2023 | Ley 29733 (Peru)
Estado del informe:	APROBADO - El agente valido todos los hallazgos correctamente.

---

1. Resumen Ejecutivo

Se identificaron cuatro hallazgos: dos de nivel ALTO (tabla persona y tabla usuario) y dos de nivel MEDIO (tabla log_acceso y tabla tratamiento_dato). No se detectaron hallazgos de nivel BAJO.

Distribucion de Hallazgos por Nivel de Riesgo

Nivel	Cantidad	Descripcion
ALTO	2	Requiere accion inmediata. Incumplimiento normativo directo.
MEDIO	2	Controles parciales. Debe subsanarse antes de la siguiente auditoria.
BAJO	0	Oportunidades de mejora identificadas.

---

2. Hallazgos Detallados

Hallazgo 1 — Tabla: persona	ALTO
Campos afectados:	dni, nombres, apellidos, fecha_nacimiento, correo, telefono, direccion, religion, discapacidad
Descripcion:	La tabla almacena datos personales y datos sensibles sin evidencia de finalidad documentada, sin cifrado en reposo ni clasificación de información, lo que vulnera los principios de minimización, seguridad y limitación de conservación.
Evidencia en el esquema:	CREATE TABLE persona (id_persona INT PRIMARY KEY AUTO_INCREMENT, dni VARCHAR(8) NOT NULL, nombres VARCHAR(100) NOT NULL, apellidos VARCHAR(100) NOT NULL, fecha_nacimiento DATE, correo VARCHAR(150), telefono VARCHAR(15), direccion VARCHAR(250), religion VARCHAR(80), discapacidad VARCHAR(100), created_at DATETIME DEFAULT CURRENT_TIMESTAMP);
Riesgo potencial:	Exposición de datos identificadores y sensibles que podrían ser utilizados para discriminación, suplantación de identidad o vulnerar derechos de los titulares.
Informacion adicional requerida:	Política de retención, base legal documentada para cada dato, mecanismos de cifrado y clasificación de la información, y registro de actividades de tratamiento asociado.
Recomendacion:	Implementar cifrado de los campos sensibles (p. ej. AES-256 en reposo), clasificar la tabla como "Confidencial", definir y documentar la finalidad y base legal de cada columna, aplicar el principio de minimización eliminando datos innecesarios y establecer una política de retención con borrado automático.
Criterio normativo:	ISO 27701:2025, control 8.3 - Minimización de datos

Hallazgo 2 — Tabla: usuario	ALTO
Campos afectados:	password, username, rol, ip_ultimo_acceso, ultimo_acceso
Descripcion:	El campo password se almacena sin indicación de hash o cifrado, lo que constituye un riesgo alto de compromisos de credenciales y acceso no autorizado a datos personales.
Evidencia en el esquema:	CREATE TABLE usuario (id_usuario INT PRIMARY KEY AUTO_INCREMENT, id_persona INT NOT NULL, username VARCHAR(60) UNIQUE NOT NULL, password VARCHAR(255) NOT NULL, rol ENUM('admin','auditor','operador') NOT NULL, ultimo_acceso DATETIME, ip_ultimo_acceso VARCHAR(45), activo BOOLEAN DEFAULT TRUE, FOREIGN KEY (id_persona) REFERENCES persona(id_persona));
Riesgo potencial:	Robo de credenciales que permitiría acceso a la tabla persona y a otros recursos, comprometiendo la confidencialidad e integridad de los datos personales.
Informacion adicional requerida:	Mecanismo de hash utilizado, política de contraseñas, auditoría de accesos a la tabla usuario.
Recomendacion:	Almacenar passwords usando un algoritmo de hash fuerte con sal (p. ej. Argon2id), aplicar políticas de complejidad y rotación, y restringir el acceso al campo mediante RBAC con privilegios mínimos.
Criterio normativo:	ISO 27701:2025, control 8.6 - Seguridad del tratamiento

Hallazgo 3 — Tabla: log_acceso	MEDIO
Campos afectados:	ip_origen, tabla_accedida, accion, fecha_hora
Descripcion:	Los registros de acceso contienen direcciones IP que son datos personales; no se aplican medidas de enmascaramiento ni retención limitada, lo que genera un riesgo medio de identificación de usuarios y de uso indebido de la información.
Evidencia en el esquema:	CREATE TABLE log_acceso (id_log INT PRIMARY KEY AUTO_INCREMENT, id_usuario INT NOT NULL, tabla_accedida VARCHAR(100), accion ENUM('SELECT','INSERT','UPDATE','DELETE'), fecha_hora DATETIME, ip_origen VARCHAR(45), FOREIGN KEY (id_usuario) REFERENCES usuario(id_usuario));
Riesgo potencial:	Posible correlación de IP con actividades específicas que permita rastrear a los titulares y vulnerar su privacidad.
Informacion adicional requerida:	Política de retención de logs, procedimientos de enmascaramiento en entornos de prueba y controles de acceso a la tabla de logs.
Recomendacion:	Aplicar enmascaramiento de direcciones IP en entornos no productivos, definir un periodo de retención (p. ej. 90 días) y eliminar automáticamente los registros, y restringir el acceso a la tabla mediante roles con privilegios de solo lectura para auditorías.
Criterio normativo:	ISO 27001:2022, control A.8.11 - Enmascaramiento de datos

Hallazgo 4 — Tabla: tratamiento_dato	MEDIO
Campos afectados:	base_legal, transferencia_internacional, pais_destino, plazo_conservacion, medidas_seguridad
Descripcion:	La tabla registra actividades de tratamiento pero no se evidencia la aplicación de medidas de seguridad, ni la existencia de mecanismos legales para transferencias internacionales ni de una política de conservación, generando un riesgo medio de incumplimiento normativo.
Evidencia en el esquema:	CREATE TABLE tratamiento_dato (id_tratamiento INT PRIMARY KEY AUTO_INCREMENT, nombre VARCHAR(200), finalidad VARCHAR(500), base_legal VARCHAR(200), responsable VARCHAR(150), destinatarios TEXT, transferencia_internacional BOOLEAN DEFAULT FALSE, pais_destino VARCHAR(100), plazo_conservacion VARCHAR(100), medidas_seguridad TEXT);
Riesgo potencial:	Transferencia de datos fuera del territorio peruano sin garantías equivalentes y retención indefinida que podría vulnerar el Art.16 de la Ley N°29733.
Informacion adicional requerida:	Documentación de los mecanismos legales para transferencias internacionales, criterios de evaluación de la medida de seguridad y política de retención concreta.
Recomendacion:	Incluir en la tabla los contratos tipo de Cláusulas Contractuales Estándar o certificaciones de adecuación, definir y registrar el plazo de conservación con borrado automático, y detallar las medidas técnicas (cifrado, DLP, auditorías) aplicadas a cada tratamiento.
Criterio normativo:	ISO 27701:2025, control 8.7 - Transferencia internacional